

> Hardening Email Sender Authentication:
A Lab-Based Evaluation of SPF/DKIM/DMARC
Misconfigurations

Guilherme Ferreira João Oliveira Ayrton da Cruz Ana Lúcia Ferreira

Faculdade de Engenharia - Universidade do Porto

May 27, 2026

> Table of Contents

1 Introduction

- Why Email Spoofing Still Works
- Research Questions & Contributions
- Lab Architecture
- Experimental Workflow
- Development Highlights

2 Authentication Protocols

- SPF, DKIM and DMARC
- Potential Misconfigurations

3 Spoofing Attacks

- Spoofing with SPF only
- Open Source Email Spoofer Tool

4 Analysis and Detection

- SMTP Artefact Analysis
- ML Espoofing Detector

5 Results and Hardening

- Authentication Hardening
- Results
- Conclusions & Future Work

> Introduction

loading module...

> Why Email Spoofing Still Works

» Problem

Phishing campaigns still succeed because email sender authentication is often misconfigured or only partially deployed.

Attackers can impersonate trusted identities even when some authentication mechanisms seem to be enabled.

» Project Goal

Build a controlled lab to reproduce spoofing attacks.

Systematically analyze how SPF, DKIM and DMARC misconfigurations affect spoofing success and how to fix them.

> Research Questions & Contributions

» Preliminary Studies

Under which SPF, DKIM and DMARC configurations does spoofing still succeed?

How do protocol composition flaws (e.g., relaxed alignment, parser inconsistencies) impact authentication?

Can SMTP artefacts be used to detect spoofed emails automatically?

» Development Contributions

Docker-based lab for sender-authentication experiments.

Systematic exploration of SPF/DKIM/DMARC misconfigurations.

Evaluation of infrastructure hardening and ML-based detection.

» Lab Docker Network Setup

Isolated Docker network with four main containers:

- DNS server (BIND) hosting SPF/DKIM/DMARC records.

- Victim mail server (Postfix + Dovecot).

- Attacker container running swaks and Espoofer.

- Webmail client for victim-side inspection.

No connectivity to the real Internet to keep attacks contained.

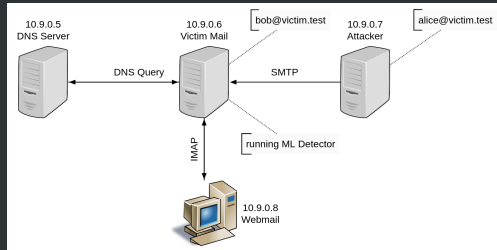


Figure: Docker-based isolated mail infrastructure

> Experimental Workflow

» Project Development

Infrastructure setup: Docker, BIND, Postfix/Dovecot, webmail.

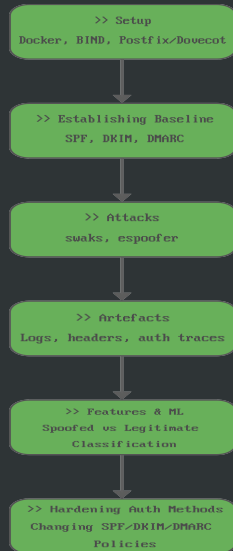
Authentication baseline: SPF, DKIM, DMARC behaviour.

Spoofing attacks: swaks, espoofer, custom scripts.

SMTP artefact collection: logs, headers, authentication traces.

Feature extraction and ML-based spoofing detection.

Infrastructure hardening and re-evaluation.



> Development Highlights

» SpoofMaster

Helper tool to orchestrate spoofing tests inside the lab.

Wraps `attack.sh` script using `swaks` - aka. Swiss Army Knife.

Produces artefacts later used for ML-based detection.

```
** Welcome to SpoofMaster - SPF/DKIM/DMARC Bypass Demo - SEED Labs **
```

> Authentication Protocols

loading module...

> SPF, DKIM and DMARC Overview

» Roles

SPF validates the sending IP against the domain in the SMTP envelope (MAIL FROM).

DKIM attaches a cryptographic signature that covers selected headers and body.

DMARC combines SPF/DKIM results and enforces domain alignment and policy.

» Insight

Authentication does not automatically mean security: misconfiguration or weak policies can still allow spoofed messages to be delivered.

> Where Misconfigurations Appear

» Examples from the Lab

SPF: `v=spf1 mx ~all` (soft-fail, accepts suspicious senders).

DKIM: selector not published or key mismatch.

DMARC:

`v=DMARC1; p=none; aspf=r; adkim=r` (monitoring only, relaxed alignment).

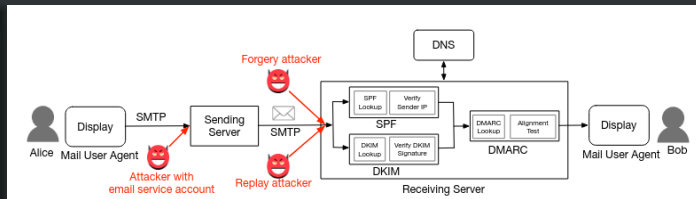


Figure: Image from Chen et al. 2020

» Impact

Suspicious mail is accepted or only logged.
Spoofed visible identities are not blocked.

> Spoofing Attacks

loading module...

> SPF-Based Spoofing Scenario

» Setup

SPF configured with soft-fail (~all) and permissive host entries.

Attacker sends mail using swaks with:

Envelope sender: `attacker@attacker.test`.

Visible From: header: Alice <`alice@victim.test`>.

» Observation

SPF can pass because the envelope sender is allowed.

The user still sees a spoofed identity in the visible From header.

> Advanced Authentication Bypass (espoofer)

» Attack Goal

Exploit composition flaws and parser inconsistencies to bypass SPF, DKIM and DMARC simultaneously.

» Techniques

Carefully crafting multiple From headers.

Taking advantage of relaxed alignment and inconsistent header parsing.

Using Espoofer to automate complex SMTP interactions.

» Result

Spoofed emails can still be delivered even though all three mechanisms appear to be deployed.

> Analysis and Detection

loading module...

> SMTP Artefact Analysis

» Collected Artefacts

Authentication-Results headers (SPF, DKIM, DMARC outcomes).

Mail logs from the victim mail server and DNS logs from BIND.

Header anomalies (multiple From, inconsistent domains).

» Purpose

Understand why specific messages pass or fail authentication (e.g., DKIM selector not found vs. signature mismatch).

Transform artefacts into features for ML-based detection.

> ML-Based Spoofing Detection

» Feature Engineering

Authentication outcomes (SPF, DKIM, DMARC).

Domain alignment indicators (match/mismatch).

Header and path anomalies derived from SMTP traces.

» Classifier Role

Distinguish legitimate vs. spoofed emails even under weak policies.

Act as a final defensive layer when protocol-level checks are bypassed.

> Results and Hardening

loading module...

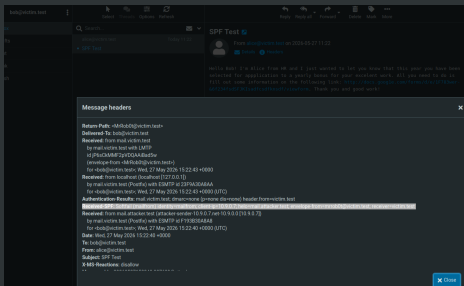
> Infrastructure Hardening

» Before (Vulnerable)

SPF: soft-fail, permissive includes.

DKIM: keys not published or misconfigured.

DMARC: policy p=none, relaxed alignment.



```
root@attacker:/home/seed/attacks# ./attack.sh spf MrRob@victim.test bob@victim.test "Hello Bob! I'm Alice from HR and I just wanted to let you know that this year you have been selected for application to a yearly bonus for your excellent work. All you need to do is fill out some information on the following link: http://docs.google.com/forms/d/e/1F783wer-667234fnd-SF3KJdandfcsdusd//viewform. Thank you and good work!" - alice@victim.test

== Trying 10.9.0.6:25...
== Connected to 10.9.0.6.
0000: 32 32 30 20 60 61 60 6C 2E 76 69 63 74 69 6D 2E 250-mail.victim.
0010: 74 65 73 74 20 45 53 4D 54 50 8D 0A test.ESMTP..
-- 220 mail.victim.test ESMTP
-- EHLO mail.attacker.test
0000: 45 48 4C 4F 20 60 61 69 6C 2E 61 74 74 61 63 6B EHLO.mail.attacker.test..
0010: 65 72 2E 74 65 74 6D 0000: 32 35 20 40 61 69 6C 2E 76 69 63 74 69 6D 2E 250-mail.victim.test..250-PIPELINING.260-SIZE 10240000.250-ETRN.250-ENHANCEDSTATUSCODES.250-8BITMIME.250-CHUNKING.
-- MAIL FROM:<MrRob@victim.test>
0000: 4D 41 49 4C 20 46 52 4F 4D 3A 3C 4D 72 52 6F 62 MAIL FROM:<MrRob@victim.test>.
0010: 38 74 40 76 69 63 74 69 6D 2E 74 65 73 74 3E 0D
0032: 0A
0000: 32 35 30 20 32 2E 31 2E 30 2D 4F 68 0D 0A 250.2.1.0.0k..
-- RCPT TO:<bob@victim.test>
0000: 52 43 50 54 20 54 4F 3A 3C 62 6F 62 40 76 69 63 RCPT.TO:<bob@victim.test>.
0010: 74 69 6D 2E 74 65 73 74 3E 0D 0A
0000: 35 30 20 2E 74 65 73 74 3E 0D 0A
0010: 69 63 74 69 6D 2E 74 65 73 74 3E 3A 20 52 65 victim.test>..Re
0032: 63 69 70 69 65 6E 74 20 61 64 64 72 65 73 73 20 cipient.address..
0040: 72 65 64 65 73 74 65 64 3A 20 6D 65 73 73 61 67 Rejected Message
0060: 65 20 72 65 6A 63 63 74 65 64 20 64 75 65 20 74 e.rejected.due.t
0080: 3A 20 50 46 20 68 61 69 6C 20 2D 20 6E 6F o.SP.Fail.-no
0090: 20 61 75 74 68 6F 72 69 7A 65 64 2E 0D 0A t.authorized..
-- QUIT
0000: 51 55 49 54 8D 0A QUIT..
0000: 32 32 31 20 32 2E 30 2E 30 2D 42 79 65 0D 0A 221.2.0.0.Bye..
-- Connection closed with remote host.

Email Headers
23 <- 250 CHUNKING
24 -> MAIL FROM:<MrRob@victim.test>
25 <= 0000: 4D 41 49 4C 20 46 52 4F 4D 3A 3C 4D 72 52 6F 62 MAIL FROM:<MrRob@victim.test>.
26 <= 0010: 38 74 40 76 69 63 74 69 6D 2E 74 65 73 74 3E 0D
27 <= 0032: 0A
-- 250 2.1.0.0k
29 <- 250 2.1.0.0k
30 -> RCPT TO:<bob@victim.test>
31 <= 0000: 52 43 50 54 20 54 4F 3A 3C 62 6F 62 40 76 69 63 RCPT.TO:<bob@victim.test>.
32 <= 0010: 74 69 6D 2E 74 65 73 74 3E 0D 0A
33 <= 0000: 35 30 20 2E 74 65 73 74 3E 3A 20 52 65 victim.test>..Re
34 <= 0010: 76 69 63 74 69 6D 2E 74 65 73 74 3E 3A 20 52 65 victim.test>..Re
```

» After (Hardened)

SPF: strict -all and limited authorized hosts.

DKIM: properly published selector and validated key.

DMARC: p=reject with strict alignment for SPF and DKIM.

> Experimental Results

» Spoofing Success vs. Configuration

No authentication or very weak policies: attacks consistently succeed.

SPF-only or DMARC with monitoring: many spoofed emails still delivered.

Fully hardened SPF/DKIM/DMARC: tested attacks are blocked or flagged by ML.

» Key Observation

Defence-in-depth and correct protocol composition are required; each mechanism alone is insufficient.

> Conclusions & Future Work

» Key Lessons

Misconfiguration and weak composition of SPF, DKIM and DMARC make spoofing feasible.
Reproducible infrastructure allows safe experimentation and clear hardening guidelines.
ML-based detection complements protocol-level authentication.

» Future Work

Extend the lab with more diverse real-world configurations and datasets.
Refine DKIM/DMARC handling and detection features.
Explore usability aspects and deployment recommendations.

> References

loading module...

> References I



J. Chen, V. Paxson, and J. Jiang, “Composition kills: A case study of email sender authentication,” in *Proceedings of the 29th USENIX Security Symposium (USENIX Security 2020)*, 2020, pp. 2183–2199. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity20/presentation/chen-jianjun>



J. Chen, “Espoofer: An email spoofing testing tool,” <https://github.com/chenjj/espoofer>, accessed: 2026-03-16.



Infraforge, “Spf, dkim, dmarc: Common setup mistakes,” <https://www.infraforge.ai/blog/spf-dkim-dmarc-common-setup-mistakes>, 2026, accessed: 2026-03-16.



DMARCLY, “How to implement dmarc/dkim/spf to stop email spoofing/phishing: The definitive guide,” <https://dmarcly.com/blog/how-to-implement-dmarc-dkim-spf-to-stop-email-spoofing-phishing-the-definitive-guide>, 2024, accessed: 2026-03-16.

> References II



OWASP Foundation, “A02:2025 – security misconfiguration,” https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/, 2025, accessed: 2026-03-16.



——, “A07:2025 – authentication failures,” https://owasp.org/Top10/2025/A07_2025-Authentication_Failures/, 2025, accessed: 2026-03-16.



Roobal, R. Saxena, and V. Dillu, “Real-time email spoofing detection using machine learning and timestamp anomaly analysis,” <https://jatit.org/volumes/Vol103No23/28Vol103No23.pdf>, 2025, accessed: 2026-03-18.



J. Chen, V. Paxson, and J. Jiang, “Composition kills: A case study of email sender authentication,” in *29th USENIX Security Symposium (USENIX Security 20)*. USENIX Association, Aug. 2020, pp. 2183–2199. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity20/presentation/chen-jianjun>